

Security & Compliance Checklist

This checklist outlines critical security, privacy and compliance measures that must be implemented before deploying the SkillConnect JK platform. It is intended for the development and operations teams, as well as stakeholders (banks, government) to ensure the system meets regulatory requirements and protects sensitive data.

1. Regulatory & Legal Compliance

- **KYC/AML Regulations:** Ensure KYC procedures conform to RBI guidelines (Aadhaar eKYC via DigiLocker). Verify that PMLA (Prevention of Money Laundering Act) obligations are met (transaction monitoring, suspicious activity reports).
- **Data Privacy:** Comply with India's IT Act, 2000 and rules on Reasonable Security Practices. Provide privacy policy in multiple languages. Obtain explicit user consent for data collection and sharing.
- **Digital Lending Guidelines:** Adhere to RBI digital lending norms (clarity of loan terms, interest rates, fees, cool-off periods). Ensure no unregulated recovery practices.
- **Priority Sector Lending Reporting:** Provide data exports to banks for PSL reporting[1], including loan amounts and demographics.
- **Credit Information Companies:** If retrieving credit history, obtain written consent and ensure compliance with Credit Information Companies Regulation Act (CICRA).

2. Authentication & Access Control

- **Multi-Factor Authentication (MFA):** Enforce MFA for admin and bank user accounts. Offer optional MFA for learners and TPs.
- **Password Policies:** Minimum length, complexity requirements and periodic expiration. Store passwords hashed using a strong algorithm (e.g. bcrypt/argon2).
- **Role-Based Access Control (RBAC):** Implement granular roles (Learner, TP, BankUser, Admin). Ensure endpoints and data queries are authorised based on roles.
- **Session Management:** Use JWT with short expiration and refresh tokens. Protect tokens via HTTP-only cookies or secure storage.

3. Data Encryption & Storage

- **Transport Layer Security (TLS):** All traffic between client, API gateway and internal services must use TLS 1.2+.

- **Encryption at Rest:** Encrypt the database (disk-level encryption). Use field-level encryption for sensitive fields (Aadhaar number, financial information).
- **Secure Key Management:** Store encryption keys in a managed secrets vault (e.g. AWS KMS, HashiCorp Vault). Rotate keys periodically.
- **Logging & Auditing:** Logs must be tamper-evident. Do not log sensitive data. Implement audit trails for changes to critical data (loan approval, disbursements). Retain logs per regulatory requirements.

4. Input Validation & Application Security

- **Input Sanitisation:** Validate and sanitise all user inputs (forms, API) to prevent SQL injection, XSS and injection attacks. Use parameterized queries in ORM.
- **Rate Limiting & Throttling:** Implement per-IP and per-user rate limits to deter automated abuse and denial of service.
- **Secure Coding Practices:** Follow OWASP Top Ten guidelines. Conduct code reviews and static analysis (e.g. SonarQube) on every CI run.
- **CSRF Protection:** Use anti-CSRF tokens on web forms and verify origins.
- **Clickjacking Protection:** Set appropriate X-Frame-Options and Content-Security-Policy headers.

5. Infrastructure & Network Security

- **Firewalls & Security Groups:** Restrict inbound/outbound traffic to necessary ports and IPs. Isolate internal services in private subnets.
- **API Gateway Security:** Enforce request validation, IP whitelisting for bank integration endpoints and DDoS protection.
- **Container Hardening:** Use minimal base images, regular patching and vulnerability scanning. Run containers with least privileges (drop root).
- **Disaster Recovery:** Configure regular database backups with tested restoration procedures. Use multi-AZ deployment for high availability.

6. Payment & Banking Integrations

- **PCI DSS Compliance:** Although the platform does not store card data, ensure payment gateway partners are PCI DSS compliant. Do not store card or UPI credential details.
- **UPI / NACH Mandate Security:** Ensure UPI AutoPay integration follows NPCI guidelines. Securely store mandate IDs and never reveal them to unauthorised users. Provide ability to revoke mandates.
- **API Credentials:** Bank and payment gateway API credentials must be stored in a secure secrets store. Rotate periodically.

7. Monitoring & Incident Response

- **Real-Time Monitoring:** Set up metrics (CPU, memory, error rates), logging and alerting. Use tools like Prometheus/Grafana and ELK stack.
- **Security Information and Event Management (SIEM):** Aggregate security logs and set up rules for detecting anomalies and intrusions.
- **Incident Response Plan:** Document procedures for identifying, reporting and responding to security incidents. Include roles and responsibilities, escalation contacts and communication templates.
- **Penetration Testing:** Conduct regular third-party penetration tests and vulnerability assessments. Address findings promptly.

8. User Education & Support

- **Security Awareness:** Educate learners and TPs about phishing, safe password practices and how the platform protects their data.
- **Support Channels:** Provide secure channels (helpline, chat support) for users to report suspicious activity or request help.
- **Complaint Redressal:** Design a transparent grievance mechanism; log and respond to complaints within defined timeframes.

9. Compliance Certifications (Future)

- Aim for ISO/IEC 27001 certification for information security management systems once platform scales.
- Explore certification under MeitY's Digital Lending guidelines.

10. Pre-Deployment Checklist

Item	Responsible Team	Status
Regulatory compliance review completed	Legal & Compliance	
Threat model & risk assessment finalised	Security & Architecture	
Encryption keys configured & tested	DevOps	
Penetration testing conducted & issues fixed	External Security Vendor	
Disaster recovery tested	DevOps & Database	
Role-based access matrix verified	Product & Engineering	
Privacy policy & user agreements finalised	Legal & Product	
User training materials prepared	Support & Communications	
Pilot stakeholder sign-off (bank, gov, TP)	Programme Management	

<https://www.go-yubi.com/securitisation/priority-sector-lending/>